

Conclusion: The Composition That Matters

## Conclusion: The Composition That Matters I

This review began with two ways to lose: exploitation, in which an attacker crosses a boundary from a compromised component, and authorized misuse, in which an agent uses legitimate authority as directed by hostile content sec. 3. The first path is the traditional target of operating-system security. The second is the new one, it needs no kernel exploit, and it is governed by the same principles that disciplined the first: least privilege, complete mediation, and the separation of proposal from authorization (Saltzer and Schroeder 1975). What has changed is the cast — agents that generate code, configuration, and policy faster than any prior tooling — and the pace at which a persuasion failure becomes a deployed change.

## Conclusion: The Composition That Matters I

Evaluation by properties rather than labels kept the comparison honest across the 216-cell stance matrix of sec. 4. The platform reviews locate the current frontier. Qubes supplies the strongest deployable compartmentalization under operational conditions, and its own documentation states what it does not buy sec. 5. NixOS supplies reproducible, auditable operations that are not by themselves confinement sec. 6. The conventional desktops show how far documented hardening can be pushed before usability pushes back sec. 7; the server candidates re-litigate isolation per workload rather than by label sec. 8; and the comparators mark the verification and design frontier without closing the deployment gap sec. 9.

## Conclusion: The Composition That Matters I

The three extension domains carry the argument to the layers where agents actually operate. Cognitive security (sec. 11) treats the operator-agent interface as an attack surface and makes the authorized-misuse path concrete. Operator OpSec (sec. 12) answers it with discipline: identity compartmentalization across agent contexts, data-loss path analysis that includes the model provider, tool-bridge grants reviewed as authority, ambient-token hygiene, untrusted intake, and a rehearsed response that assumes exfiltration of everything the task could touch. Orchestration security (sec. 13) secures the layer above: the orchestrator is a privileged intermediary, delegation chains are confused-deputy structures (Hardy 1988; Lampson 1974), the tool broker is the complete-mediation point, and approval lives outside the hierarchy. Configuration authorization (sec. 14) completes the set: generation is not authorization, and the 9 invariants draw the line an

## Conclusion: The Composition That Matters I

agent must never be able to cross, whatever it can write.

The forecast (sec. 15) commits to composition over miracle: compartmentalization grows more valuable as failures grow more frequent, capability mediation rises to parity with exploit mitigation, trustworthy replacement outruns elaborate repair, small interfaces deserve disproportionate investment, and coherent defaults outrun hardening menus. None of this is a promise about any release; all of it is a claim about which properties matter while the 2028–2031 window passes.

## Conclusion: The Composition That Matters I

The landscape around this prospectus is consolidating faster than the manuscript's own timeline assumed. Standards bodies now name the agentic layer as a security object: OWASP publishes both an agentic threats-and-mitigations guide and a Top 10 for agentic applications (Foundation 2025a, 2025b); the Cloud Security Alliance contributes the MAESTRO threat-modeling framework and the AegisSwarm zero-trust swarm architecture (Alliance 2025, 2026); NIST has opened an AI Agent Standards Initiative to coordinate exactly the identity, authorization, and incident-handling questions this review places at the orchestration layer (Standards and Technology 2026); and the European Union's AI Act transparency obligations for AI agents, applicable from 2 August 2026, make disclosure of the acting agent a legal requirement rather than a design preference (Commission 2026). Meanwhile the coding-agent platforms have already answered the deployment question the prospectus

## Conclusion: The Composition That Matters I

raises: Claude Code sandboxes execution with OS primitives, routes egress through a proxy, and escalates classifier-flagged actions for review; OpenAI Codex renders one sandbox policy through Seatbelt, Bubblewrap, Landlock, or Windows ACLs with network access off by default; Gemini CLI ships sandbox profiles built on the same families of mechanism (Anthropic 2026; OpenAI 2026; Google 2026). Three competing vendors, building independently, converged on the same triad — OS-primitive sandboxing, proxy-mediated egress, classifier-gated escalation. That convergence is the strongest external evidence this review can offer for its core claim: capability mediation is becoming the industry default, not a proposal awaiting adoption, and the open work is making the mediation layer coherent with the operating-system boundaries below it rather than inventing it.

## Conclusion: The Composition That Matters I

The prospectus is therefore specific about what to build next:

## Conclusion: The Composition That Matters I

- ▶ **Capability mediation layers** that make every agent tool call a checked decision — operation, artifact, destination, scope, expiry — with the decision point outside the agent and the policy separate from the task.
- ▶ **Small verified interfaces** at the places where authority crosses domains, built and maintained as the disproportionate targets they are (Klein et al. 2009).
- ▶ **Disposable execution with external approval chains**, in which task environments are rebuilt rather than trusted, and consequential actions require an approval no component in the hierarchy can grant itself.
- ▶ **Auditable declarative baselines** in which intended system state is explicit, reviewable, reproducibly deployable — and independently authorized before deployment.

## Conclusion: The Composition That Matters I

The 11 figures and the underlying analysis artifacts are reproducible from the repository's own pipeline, because a prospectus about independently rebuildable environments should be one. The composition that matters is not any single system. It is the set of boundaries an operator can actually keep: workstations that compartmentalize, operations that rebuild, updates that authenticate, and agents that can propose everything while authorizing almost nothing. Building those, in pieces that someone demonstrably maintains, is the work this horizon rewards.

## Conclusion: The Composition That Matters I

Finally, the skill library under `skills/` is the operational form of this prospectus: the review's concepts are available as nine harness-neutral skills, not only as prose.